

BRIAN SANTIAGO

GRC Analyst | Compliance & Audit Readiness | Risk Management | TPRM | NIST CSF | ISO 27001 | SOX ITGC | Security+
| ISO 27001 Lead Auditor
Ocala, FL | 631-456-1539 | briand.santiago@gmail.com | linkedin.com/in/briansantiago-grc |
github.com/BrianSantiago-GRC/grc-portfolio

PROFESSIONAL SUMMARY

GRC Analyst with 3+ years of IT compliance, audit readiness, and risk management experience across regulated healthcare and education environments. Certified ISO 27001 Lead Auditor with hands-on track record in continuous audit readiness, control testing, evidence collection, remediation tracking, risk register maintenance, TPRM vendor lifecycle management, and policy lifecycle development. Built and published a 9-artifact GRC portfolio demonstrating applied cross-framework control mapping, gap analysis, and audit-ready documentation. Translates complex regulatory requirements into actionable, scalable controls and communicates compliance posture clearly to both technical and non-technical stakeholders.

GRC PORTFOLIO — [GITHUB.COM/BRIANSANTIAGO-GRC/GRC-PORTFOLIO](https://github.com/BrianSantiago-GRC/grc-portfolio)

- Needed practical GRC work samples showing applied cross-framework knowledge — built a 9-artifact portfolio including an ISO 27001 ISMS (scope, SoA, Annex A gap analysis, risk treatment plan), NIST CSF 2.0 assessment, NIST SP 800-30 risk register, HIPAA audit checklist, TPRM questionnaire, incident response plan, and access control policy templates, all mapped to real control objectives and audit evidence standards.
- Controls, risks, and evidence sources were disconnected across frameworks — created a cross-framework control mapping layer linking ISO 27001 Annex A, NIST CSF, and HIPAA to a shared evidence register, producing a scalable, audit-ready structure reusable across multiple compliance requirements.

CORE COMPETENCIES

GRC Program Operations: Continuous Audit Readiness, Control Testing, Evidence Collection, Remediation Tracking, Policy Lifecycle Management, Security Posture Reporting, Program Maturity, Corrective Actions

Frameworks & Standards: NIST CSF 2.0, NIST SP 800-30/53/61, ISO 27001:2022, ISO 27005, SOC 2 Type I/II, SOX ITGC, HIPAA, FERPA, PCI DSS, CIS Controls

Risk & Audit Operations: Risk Register Maintenance, Gap Analysis, Access Reviews, CAPA Documentation, Control Mapping, POA&M Exposure, Deficiency Tracking, Audit Walkthrough Support

Third-Party Risk (TPRM): Vendor Lifecycle Management, Security Questionnaires, SOC 2 Report Review, ISO 27001 Evidence Review, Due Diligence Documentation, Cross-Functional Stakeholder Collaboration

GRC Tools & Technology: Drata/Vanta (Concepts), KnowBe4 (Security Awareness), LogicGate (Familiar), Active Directory, Entra ID, Microsoft 365, ServiceNow, NinjaOne, Splunk, PowerShell

PROFESSIONAL EXPERIENCE

IT Support Specialist — GRC & Compliance Focus | [Ina A. Colen Academy](#) | Ocala, FL | Jul 2025 – Present

- Compliance evidence was siloed across Microsoft 365, Google Workspace, AD, and endpoint tools with no audit trail — built a structured evidence collection workflow aligned to HIPAA, FERPA, ISO 27001, and NIST CSF controls, reducing evidence rework during review cycles and producing audit-ready packages on demand.
- Access reviews lacked documentation consistency and least-privilege traceability — managed the full identity lifecycle (joiner, mover, leaver) for 500+ users across AD, Entra ID, Microsoft 365, and Google Workspace, producing access review records that directly supported SOX ITGC-style control evidence.
- Policy and SOP gaps created inconsistent security practices across departments — developed and maintained a policy library aligned to ISO 27001 Annex A, NIST CSF, and internal control expectations, improving framework coverage and reducing audit findings tied to undocumented procedures.
- Endpoint remediation tracking was informal and hard to evidence — tracked patching, GPO hardening, and configuration remediation across 200+ endpoints via NinjaOne and Microsoft tools, enabling clear corrective action closure rates reportable to management.
- Manual evidence processes were creating time waste and inconsistency — built n8n-automated evidence templates and gap summaries that reduced manual drafting time by an estimated 40%, strengthening continuous audit readiness across recurring compliance cycles.
- Leadership needed compliance posture reporting, not raw technical output — translated access control findings, endpoint configurations, and remediation outcomes into clear compliance summaries for stakeholder review and audit walkthrough support.

Tier 3 IT Support Specialist | [Sanitas Medical Center](#) | Remote / FL | Jan 2025 – May 2025

- HIPAA and SOX ITGC audits required complete, organized operational evidence — gathered access control records, workstation configuration details, change logs, and remediation notes into structured work paper packages that supported audit walkthroughs and external reviewer requests.
- Recurring security and access issues lacked root cause documentation — used Splunk log review, Event Viewer, Wireshark captures, VPN logs, and Entra sign-in data to produce CAPA-style root cause records, enabling corrective actions to be tracked to closure.
- Patch and configuration changes needed a defensible audit trail — validated and documented patching, change records, and endpoint hardening across Windows Server, Microsoft 365, and cloud services, supporting both operational continuity and control effectiveness evidence.
- Technical findings were not reaching compliance stakeholders in usable form — translated access, endpoint, and security issues into compliance-oriented documentation consumable by non-technical operations leads and audit personnel.

IT Auditor / Help Desk Technician | KM New Living Society | New York, NY | May 2023 – Aug 2024

- SOC 1/2 ITGC reviews needed reliable access and configuration control evidence — collected AD, GPO, and access records; reviewed control design and operating effectiveness; identified and documented 12 control gaps with remediation recommendations mapped to audit control objectives.
- Vendor due diligence documentation was incomplete, creating third-party risk exposure — organized security questionnaire responses, tracked outstanding items, and maintained TPRM documentation to improve vendor review completeness and reduce gaps in the third-party risk lifecycle.
- Evidence notes were inconsistent across tickets, creating audit rework — standardized work paper documentation and remediation tracking across 400+ ServiceNow tickets, improving audit reusability and reducing rework during compliance review periods.

CERTIFICATIONS

ISO 27001 Lead Auditor | CompTIA Security+ | CompTIA Network+ | CompTIA A+ | GRC Mastery | MediClear HIPAA Compliance | Google Cybersecurity Certificate | CySA+ (In Progress — Target Q4 2026)

EDUCATION

High School Diploma — Piscataway High School, Piscataway, NJ